

Segurança em Computação em Nuvem

Fundamentos e conceitos de segurança da computação em nuvem, o modelo de responsabilidade compartilhada e as orientações da Cloud Security Alliance (CSA) para as principais áreas críticas dos ambientes em nuvem.

O que veremos hoje

1

Fundamentos e conceitos de computação em nuvem

Características essenciais, modelos de serviço (SaaS, PaaS, IaaS) e de implantação segundo o NIST (NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY.).

2

Aspectos de segurança e responsabilidade compartilhada

Princípios da segurança da informação, comparação on-premise x nuvem e a divisão de responsabilidades entre cliente e provedor.

3

Segurança nos serviços de nuvem

Máquinas virtuais, contêineres, serverless, bancos de dados, armazenamento, rede, monitoramento e auditoria.

4

Orientações da Cloud Security Alliance (CSA)

Conceitos-chave, arquitetura de referência e os quatorze domínios de segurança da CSA.

PARTE 1

Fundamentos e conceitos de computação em nuvem

Do novo paradigma da nuvem às definições consolidadas pelo NIST (NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY).

Por que estudar a segurança em nuvem?

PROPÓSITO

Compreender a importância da segurança no provimento dos serviços em nuvem e conhecer suas principais formas de manutenção e controle.

OBJETIVOS DA AULA

- 1 Reconhecer os fundamentos e os principais conceitos do paradigma da computação em nuvem.
- 2 Identificar os aspectos gerais de segurança e as responsabilidades de cada polo nos contratos de nuvem.
- 3 Identificar os aspectos de segurança dos principais serviços dos provedores de nuvem.
- 4 Reconhecer os domínios descritos nas orientações de segurança da CSA (Cloud Security Alliance) em sua versão 4.0.

INTRODUÇÃO

Da posse de hardware ao consumo de serviços gerenciados

Durante décadas, as organizações estruturaram sua infraestrutura de TI a partir da **compra de hardware, instalação de sistemas operacionais e implantação de software** — uma rotina que **exigia manutenção contínua e cara, sobretudo em segurança** (patches, backup, monitoramento).

A computação em nuvem introduziu um novo paradigma: a **capacidade de consumir serviços gerenciados** para atingir o mesmo objetivo antes alcançado pela execução local — **automatizando tarefas de segurança** que eram extremamente manuais e liberando as empresas para focar em escalabilidade e inovação.

EXEMPLO PRÁTICO

Uma empresa que hospeda seu e-mail corporativo no Google Workspace não precisa mais cuidar de servidores, patches ou backup: o provedor automatiza essas tarefas de segurança, e a equipe de TI foca no próprio negócio.

As cinco características essenciais (NIST SP 800-145)

1 On-Demand Self-Service

Autoatendimento sob demanda: o cliente provisiona hardware e sistemas sem interação física com o provedor.

2 Broad Network Access

Amplo acesso à rede, disponível a milhões de usuários finais em qualquer plataforma (celular, tablet, laptop).

3 Resource Pooling

Agrupamento de recursos: Conjunto de recursos de computação compartilhados entre clientes, maximizando o uso de CPU, memória e armazenamento.

4 Rapid Elasticity

Elasticidade rápida: capacidade de aumentar e diminuir recursos de computação conforme a necessidade do negócio.

5 Measured Service

Serviço Mensurado: a empresa paga apenas pelos recursos consumidos, com relatório de cobrança detalhado.

Os três modelos de serviço

SaaS

Software as a Service

O provedor entrega o aplicativo pronto ao cliente. Toda a gestão da infraestrutura fica transparente para quem usa.

PaaS

Platform as a Service

O cliente implanta seus próprios aplicativos usando linguagens e ferramentas suportadas pela plataforma do provedor.

IaaS

Infrastructure as a Service

O provedor oferece processamento, armazenamento e rede; o cliente instala e gerencia sistema operacional e aplicativos.

EXEMPLO PRÁTICO

Microsoft 365 e Google Workspace (SaaS);
AWS Elastic Beanstalk e Google App Engine (PaaS);
Amazon EC2, Azure Virtual Machine e Google Compute Engine (IaaS).

Os quatro modelos de implantação

1

Privada

Infraestrutura provisionada para uso exclusivo de uma única organização, podendo estar dentro ou fora de suas instalações.

2

Comunitária

Uso compartilhado por uma comunidade de clientes com preocupações em comum: missão, segurança, política e conformidade.

3

Pública

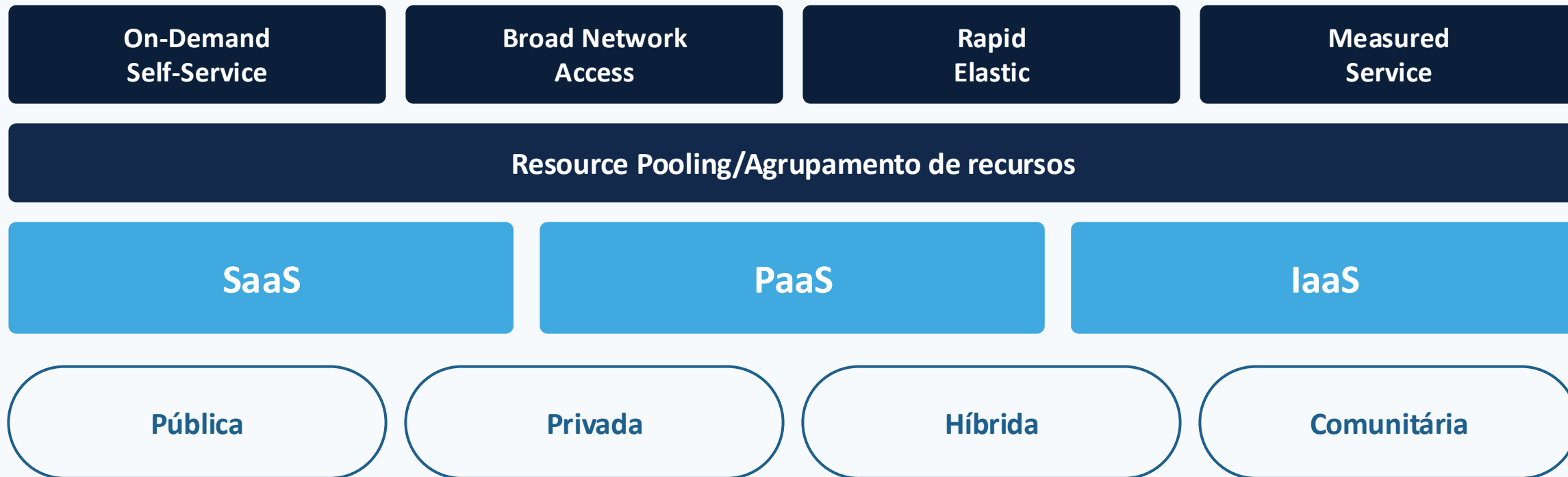
Infraestrutura provisionada para uso aberto ao público, sempre implantada nas instalações do provedor de nuvem.

4

Híbrida

Composta por duas ou mais infraestruturas (privada, comunitária ou pública) unidas por tecnologia que permite portabilidade.

Consolidação: da característica ao modelo de implantação



Características essenciais

Modelos de serviço · Modelos de implantação

O mercado de serviços de nuvem

Três grandes empresas se destacam no provimento de serviços em nuvem em grande escala: Amazon Web Services (AWS), Microsoft Azure e Google Cloud Platform (GCP).

Netflix

AWS

Um dos maiores provedores de streaming de vídeo do planeta utiliza a AWS para abrigar sua infraestrutura e rodar seus sistemas.

Mercedes-Benz

Azure

A fabricante de automóveis utiliza os serviços Azure para abrigar toda a sua área de pesquisa e desenvolvimento.

Home Depot

GCP

O maior revendedor de materiais de reforma dos EUA hospeda e roda os sistemas de suas lojas on-line na GCP.

Respostas do teste rápido

1

1. Segundo o NIST, quais são exemplos de características essenciais que uma provedora de serviços em nuvem deve apresentar?

2

2. Qual modelo de serviço permite contratar máquinas virtuais cobradas apenas pelo uso?

Respostas do teste rápido

1

1. Segundo o NIST, quais são exemplos de características essenciais que uma provedora de serviços em nuvem deve apresentar?

Autosserviço sob demanda (**On-demand self-service**), Amplo acesso à rede (**Broad network access**), Serviço mensurado (**Measured service**), Elasticidade rápida (**Rapid elasticity**) e Agrupamento de recursos (**Resource pooling**).

(características essenciais definidas pela publicação NIST SP 800-145)

2

2. Qual modelo de serviço permite contratar máquinas virtuais cobradas apenas pelo uso?

Respostas do teste rápido

1

1. Segundo o NIST, quais são exemplos de características essenciais que uma provedora de serviços em nuvem deve apresentar?

Autosserviço sob demanda (**On-demand self-service**), Amplo acesso à rede (**Broad network access**), Serviço mensurado (**Measured service**), Elasticidade rápida (**Rapid elasticity**) e Agrupamento de recursos (**Resource pooling**).

(características essenciais definidas pela publicação NIST SP 800-145)

2

2. Qual modelo de serviço permite contratar máquinas virtuais cobradas apenas pelo uso?

IaaS — Infraestrutura como Serviço (*Infrastructure as a Service*). Permite contratar máquinas virtuais e outros recursos de infraestrutura sob demanda, com cobrança baseada no uso.

PARTE 2

Aspectos de segurança e responsabilidade compartilhada

Como a nuvem redistribuiu as responsabilidades de segurança entre cliente e provedor.

Por que a segurança na nuvem importa tanto

Imagine a Mercedes-Benz guardando os segredos de toda a sua área de pesquisa e desenvolvimento em servidores sobre os quais não tem ingerência direta sobre a segurança.

Ou imagine quanto a Netflix perderia em valor se seus serviços parassem por algumas horas.

A nuvem mudou o paradigma de controle dos dados: do modelo on-premises (no local) para algo distribuído por vários cantos do globo. Manter data centers próprios demanda vultosos investimentos, e a terceirização para especialistas otimiza esses custos.

CONCEITO-CHAVE

Segurança da informação preserva confidencialidade, integridade e disponibilidade. No ramo da computação em nuvem, essa subárea é conhecida como cloud security ("nuvem segura") — e adota os mesmos princípios, adaptados ao ambiente distribuído do provedor.

Os três pilares da segurança da informação

1

Confidencialidade

Garante que as informações sejam acessadas apenas por quem detém direito para tal.

2

Integridade

Garante que as informações não sejam modificadas indevidamente em nenhuma etapa da transmissão ou do armazenamento.

3

Disponibilidade

Garante que as informações e os serviços estejam disponíveis sempre que forem necessários.

On-premise x nuvem: segurança física, dados e patches

On-premise

- Segurança física: responsabilidade exclusiva da própria organização, que controla o acesso ao seu data center.
- Localização do dado: totalmente sob controle da organização, dentro de suas próprias instalações.
- Gestão de vulnerabilidades: a aplicação de patches é encargo da equipe interna de TI.

Nuvem

- Segurança física: passa a ser encargo do provedor, que controla o acesso às suas instalações.
- Localização do dado: pode estar em qualquer lugar do planeta onde o provedor mantenha operações.
- Gestão de vulnerabilidades: o gerenciamento de patches passa ao provedor, podendo ser compartilhado conforme o modelo de serviço.

On-premise x nuvem: incidentes e conformidade

On-premise

- Resposta a incidentes: todo o encargo fica delegado à própria organização, dona dos equipamentos e dados.
- Regulações: cabe inteiramente à organização suportar as questões legais e normativas vigentes.

Nuvem

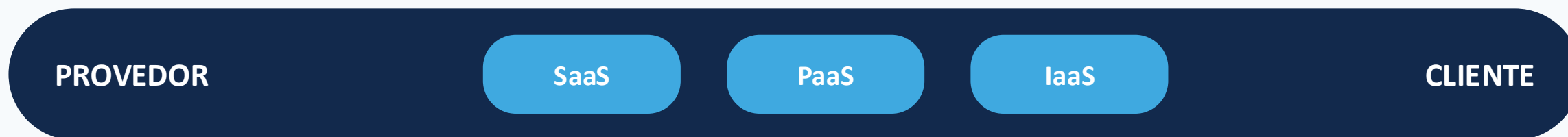
- Resposta a incidentes: torna-se compartilhada entre provedor e cliente, cada um atuando em sua esfera de ações.
- Regulações: provedor e cliente tomam medidas conjuntas para atender às exigências legais dos territórios envolvidos.

REFLEXÃO

A responsabilidade pela segurança não é binária. Os grandes provedores investem mais em proteção do que a maioria das organizações conseguiria investir sozinha.

O modelo de responsabilidade compartilhada

É a estrutura de segurança em nuvem que determina as obrigações do provedor e da organização cliente, distribuindo a responsabilidade conforme o modelo de serviço contratado (IaaS, PaaS ou SaaS).



Grau de responsabilidade sobre a segurança de acordo com o modelo de serviço

ATENÇÃO

A CSA enxerga que a responsabilidade pende mais para o cliente no modelo IaaS, o oposto acontece no SaaS, e o PaaS ocupa o meio do caminho entre as duas pontas.

A pilha de responsabilidades por modelo de serviço



Teste rápido

1. Quais são os três princípios fundamentais que a segurança da nuvem deve preservar, herdados da segurança da informação?
2. Colocando os modelos de serviço em ordem crescente de responsabilidade do cliente pela segurança, qual é a sequência correta?

Respostas do teste rápido

1

1. Quais são os três princípios fundamentais que a segurança da nuvem deve preservar, herdados da segurança da informação?

Confidencialidade, integridade e disponibilidade — que garantem, respectivamente, acesso restrito a quem tem direito, dados não alterados indevidamente e disponibilidade sempre que necessário.

2

2. Colocando os modelos de serviço em ordem crescente de responsabilidade do cliente pela segurança, qual é a sequência correta?

Respostas do teste rápido

1

1. Quais são os três princípios fundamentais que a segurança da nuvem deve preservar, herdados da segurança da informação?

Confidencialidade, integridade e disponibilidade — que garantem, respectivamente, acesso restrito a quem tem direito, dados não alterados indevidamente e disponibilidade sempre que necessário.

2

2. Colocando os modelos de serviço em ordem crescente de responsabilidade do cliente pela segurança, qual é a sequência correta?

SaaS < PaaS < IaaS — a responsabilidade do cliente aumenta à medida que ele assume mais camadas da pilha de tecnologia.

PARTE 3

Segurança nos serviços de nuvem

Computação, armazenamento, rede e monitoramento: as nuances de cada camada de serviço.

Serviço de máquinas virtuais

Para IaaS, o recurso mais comum e básico é a computação: engloba desde as tradicionais máquinas virtuais (VMs) até arquiteturas mais modernas, como contêineres e funções como serviço (serverless).

1 Selecionar máquina e sistema operacional

Escolher o tamanho da VM (vCPU e memória) e uma imagem pré-instalada (Windows ou Linux).

2 Configurar armazenamento e rede

Adicionar volumes, configurar controles de acesso à rede e microssegmentação.

3 Definir permissões de acesso

Configurar quem pode acessar cada um dos recursos provisionados na nuvem.

4 Implantar e manter

Implantar os aplicativos, ligar os serviços e aplicar patches de atualização continuamente.

Serviço de containerização

Um contêiner é uma evolução da máquina virtual: contém tudo que é necessário para a execução da aplicação (arquivos, variáveis e bibliotecas), mas compartilha o mesmo kernel do host — sem precisar de uma VM para cada aplicação.

1 Portabilidade

Um app desenvolvido em um contêiner na máquina do desenvolvedor roda em produção com milhares de instâncias.

2 Espaço reduzido

Apenas as bibliotecas e os binários necessários são armazenados dentro do contêiner.

3 Velocidade

As implantações e atualizações são muito mais rápidas se comparadas às máquinas virtuais.

FERRAMENTAS

Docker foi adotado pela indústria como padrão para encapsular contêineres; Kubernetes é o projeto de código aberto mais popular para orquestrar, implantar e gerenciar contêineres em escala.

Funções como serviço (abordagem serverless)

Embora o nome sugira que não há servidores, o serverless significa que o cliente não é responsável pela infraestrutura de computação subjacente: manutenção do sistema operacional, escala e gerenciamento de tempo de execução ficam com o provedor.

Basta importar um código, selecionar o interpretador e a quantidade de CPU e memória necessárias, e definir o gatilho que invoca a função. O serverless é orientado a eventos.

NOVO TIPO DE SERVIÇO: FAAS

Alguns provedores classificam o serverless como uma categoria própria — Function as a Service (FaaS) — além dos tradicionais IaaS, PaaS e SaaS estabelecidos pelo NIST.

EXEMPLO PRÁTICO

AWS Lambda, Azure Functions e Google Cloud Functions permitem executar código sob demanda, cobrando apenas pelo tempo de execução da função.

Serviço de bases de dados gerenciadas

Ao optar por uma base de dados gerenciada (em vez de instalar um banco dentro de uma VM), o cliente "sai" do modelo IaaS: o provedor passa a supervisionar a segurança de todo o sistema operacional e do banco de dados.

1 Manutenção e patches

A atualização de patches de segurança do banco é responsabilidade do provedor de nuvem.

2 Disponibilidade e backup

A disponibilidade é garantida pelo provedor, e os backups já vêm incluídos como parte do serviço.

3 Criptografia e auditoria

O tráfego e os dados armazenados são criptografados, com registro de logs e monitoramento incorporados.

EXEMPLO PRÁTICO

MySQL, PostgreSQL e Microsoft SQL Server gerenciados, além de bancos proprietários como Amazon DynamoDB, Azure Cosmos DB e Google Cloud Spanner.

Como e onde os dados são guardados

1 Armazenamento de arquivo

Similar ao NAS local. Suporta protocolos como NFS e SMB/CIFS, com montagem de volumes para múltiplas VMs.

2 Armazenamento de objeto

Guarda objetos em buckets, acessados via API HTTPS. Não se destina a armazenar sistemas operacionais ou bancos de dados.

3 Armazenamento de bloco

Similar a uma SAN local. O cliente monta um volume, formata-o e armazena arquivos, bancos ou sistemas operacionais inteiros.

EXEMPLO PRÁTICO

AWS, Azure e GCP oferecem serviços de armazenamento de arquivos, objetos, blocos e contêineres (CSI — Container Storage Interface, usado por orquestradores como o Kubernetes).

Ameaças e contramedidas no armazenamento

Principais ameaças

- Acesso não autorizado aos dados armazenados.
- Vazamento de dados.
- Exfiltração de dados.
- Perda de dados.

Contramedidas

- Lista de controle de acesso (ACL) e gerenciamento de identidade (IAM).
- Criptografia dos dados em trânsito e em repouso.
- Auditoria por meio de registro de logs de acesso.
- Backups para recuperação de dados apagados ou alterados.

Serviço de rede

1 DNS

Traduz nomes de host para endereços IP, com registros como Alias e CNAME, além de balanceamento de carga.

2 CDN

Armazena conteúdo em cache perto do cliente e serve como camada extra de defesa contra ataques DDoS.

3 VPN

Oferece acesso seguro a recursos privados por meio de um túnel criptografado, com uso comum de MFA.

4 WAF

Firewall de camada de aplicação, capaz de detectar e mitigar ataques comuns ao protocolo HTTP/HTTPS.

5 Proteção DDoS

Usa grupos de recursos autoescaláveis e balanceamento de carga para proteger o ambiente do cliente.

Serviço de monitoramento e auditoria

O monitoramento refere-se às atividades de registro nos serviços do ambiente de nuvem: eventos de login (sucesso e falha) e ações tomadas (quem fez o quê, quando e com qual resultado).

O registro documentado de todas as ações realizadas é a trilha de auditoria — deve ser armazenado em um repositório central de logs, com acesso limitado à necessidade de conhecimento.

SIEM

Security Information and Event Management: correlaciona logs de mais de um serviço. Se um evento ocorre no serviço A e outro no B, a conjunção pode indicar um risco muito maior do que cada evento isoladamente — reduzindo falsos positivos.

ATENÇÃO

Nem tudo deve ser registrado indiscriminadamente: uma análise de risco ajuda a decidir o que auditar, já que o armazenamento de logs pode ser explosivo em termos de consumo de recursos.

Teste rápido

1. Por que os contêineres são considerados mais leves e rápidos de implantar do que as máquinas virtuais?
2. Quando uma empresa opta por um banco de dados gerenciado em vez de instalar o banco dentro de uma VM, quem passa a ser responsável pela manutenção, pelos patches e pela disponibilidade do banco?

Respostas do teste rápido

1

1. Por que os contêineres são considerados mais leves e rápidos de implantar do que as máquinas virtuais?

Porque compartilham o mesmo kernel do host e empacotam apenas as bibliotecas e binários necessários à aplicação, sem exigir um sistema operacional completo para cada instância.

2

2. Quando uma empresa opta por um banco de dados gerenciado em vez de instalar o banco dentro de uma VM, quem passa a ser responsável pela manutenção, pelos patches e pela disponibilidade do banco?

Respostas do teste rápido

1

1. Por que os contêineres são considerados mais leves e rápidos de implantar do que as máquinas virtuais?

Porque compartilham o mesmo kernel do host e empacotam apenas as bibliotecas e binários necessários à aplicação, sem exigir um sistema operacional completo para cada instância.

2

2. Quando uma empresa opta por um banco de dados gerenciado em vez de instalar o banco dentro de uma VM, quem passa a ser responsável pela manutenção, pelos patches e pela disponibilidade do banco?

O provedor de nuvem — ao usar uma base de dados gerenciada, o cliente "sai" do modelo IaaS e transfere ao provedor a supervisão de todo o sistema operacional e do banco de dados.

PARTE 4

Orientações da Cloud Security Alliance (CSA)

Os quatorze domínios que orientam as melhores práticas de segurança em nuvem.

Apresentando a Cloud Security Alliance (CSA)

A CSA é a organização líder em escala global dedicada a definir e fomentar a conscientização sobre as melhores práticas de segurança em ambientes de computação em nuvem.

Sua missão é "promover o uso das melhores práticas para fornecer garantia de segurança na computação em nuvem e educação sobre os usos da computação em nuvem para ajudar a proteger todas as outras formas de computação".

DICA

O site cloudsecurityalliance.org mantém um blog com artigos para vários níveis de conhecimento, white papers instrutivos, cursos, certificações e um programa de associação para membros.

GUIA DE REFERÊNCIA

As orientações da CSA são publicadas no documento "Security Guidance: For Critical Areas of Focus In Cloud Computing", atualmente em sua versão 4.0.

Conceitos-chave da arquitetura em nuvem

1 Abstração

O provedor abstrai os recursos de infraestrutura física para criar o pool de recursos compartilhados.

2 Orquestração

Coordena a montagem e a entrega do pool de recursos abstraídos para os clientes.

3 Segregação

Permite que o provedor de nuvem divida os recursos entre os diferentes grupos de clientes.

4 Isolamento

Garante que um grupo não possa ver ou modificar os ativos de outro grupo dentro da nuvem.

5 Multilocação

É a junção de **segregação** com **isolamento**, aplicável entre organizações ou entre unidades de uma mesma empresa.

A arquitetura funcional da computação em nuvem

Infoestrutura

Os dados e informações — conteúdo em um banco de dados, armazenamento de arquivos etc.

Appliestrutura

Os aplicativos implantados na nuvem e os serviços subjacentes usados para construí-los.

Metaestrutura

Os protocolos e mecanismos que conectam a infraestrutura às demais camadas — o amálgama que possibilita o gerenciamento.

Infraestrutura

Os componentes principais: computação, rede e armazenamento — a base sobre a qual tudo é construído.

Processo de gestão de segurança em nuvem

1

Identificar requisitos de segurança e conformidade

2

Selecionar provedor, serviço e modelo de implantação

3

Definir a arquitetura de segurança

4

Avaliar os controles de segurança existentes

5

Identificar lacunas de controle

6

Projetar e implementar controles para preencher as lacunas

7

Gerenciar as mudanças ao longo do tempo

Os quatorze domínios da CSA

Os quatorze domínios se distribuem em três grupos, do conceitual ao operacional.

Conceitual Fundamentos	D1 Conceitos e arquiteturas de computação em nuvem			
Governança Estratégia e políticas	D2 Governança e gestão de risco corporativo	D3 Questões legais, contratos e descoberta eletrônica	D4 Gestão de conformidade e auditoria	
	D5 Governança da informação	D6 Plano de gestão e continuidade do negócio		
Operação Questões táticas e de implementação	D7 Segurança de infraestrutura	D8 Virtualização e contêineres	D9 Resposta a incidentes	D10 Segurança de aplicativos
	D11 Segurança e criptografia de dados	D12 Gerenciamento de identidade, direitos e acesso	D13 Segurança como serviço	D14 Tecnologias relacionadas

Teste rápido

1. Quais dois conceitos, segundo as orientações da CSA, compõem juntos a multilocação (multi-tenancy)?
2. Além do domínio conceitual, em quais dois grandes grupos a CSA organiza os demais domínios de segurança?

Respostas do teste rápido

1

1. Quais dois conceitos, segundo as orientações da CSA, compõem juntos a multilocação (multi-tenancy)?

Segregação e isolamento — a segregação permite dividir os recursos entre diferentes grupos, e o isolamento garante que um grupo não veja nem modifique os ativos de outro.

2

2. Além do domínio conceitual, em quais dois grandes grupos a CSA organiza os demais domínios de segurança?

Respostas do teste rápido

- 1** 1. Quais dois conceitos, segundo as orientações da CSA, compõem juntos a multilocação (multi-tenancy)?

Segregação e isolamento — a segregação permite dividir os recursos entre diferentes grupos, e o isolamento garante que um grupo não veja nem modifique os ativos de outro.

- 2** 2. Além do domínio conceitual, em quais dois grandes grupos a CSA organiza os demais domínios de segurança?

Governança e operação — os domínios de governança tratam de questões estratégicas e políticas, enquanto os de operação tratam de questões táticas e de implementação.

Considerações finais

A segurança em nuvem herda os fundamentos da segurança da informação, adaptados a um paradigma no qual a infraestrutura é gerenciada, em maior ou menor grau, por um provedor especializado.

Responsabilidade compartilhada

A divisão de encargos entre cliente e provedor varia conforme o modelo IaaS, PaaS ou SaaS contratado.

Serviços gerenciados

Computação, armazenamento, rede e monitoramento têm nuances próprias de segurança em cada provedor.

Domínios da CSA

Quatorze domínios, agrupados em conceitual, governança e operação, orientam as melhores práticas de segurança.

Referências para consulta

- CLOUD SECURITY ALLIANCE. Security Guidance: For Critical Areas of Focus In Cloud Computing v4.0 — Cloud Security Alliance, 2021.
- NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. The NIST Definition of Cloud Computing. Special Publication 800-145, 2011.
- Pesquise também sobre: Network-attached Storage (NAS), Object Store, Web Application Firewall (WAF) e Security Information and Event Management (SIEM).
- Consulte ainda: Kubernetes Container Storage Interface (CSI) Documentation, Open Container Initiative, "O que é um contêiner" e OWASP Serverless Top 10.